CYBERSECURITY AVANZATA · LEZIONE 6 DI 8

Anatomia di un'e-mail

Il mittente di un'e-mail si può scrivere come si vuole. Come fanno allora i server a capire chi l'ha mandata davvero? Leggiamo gli header come un analista di un SOC.

5G TPSI SMTP, header, SPF, DKIM, DMARC, domini sosia, BEC

PER COMINCIARE

Ti arriva una mail dal "Dirigente scolastico" che chiede di comprare subito delle gift card per un'emergenza. Che cosa controlli per primo?

SONDAGGIO

- **A** Se ci sono errori di ortografia
- **B** L'indirizzo del mittente
- **C** Il logo e la firma in fondo
- **D** Chiamo il dirigente al numero che conosco già

IL PROTOCOLLO DEL 1982

SMTP si fida di quello che gli scrivi

```
HELO mail.attaccante.example
MAIL FROM:<chiunque@chiunque.example>
RCPT TO:<vittima@scuola.example>
DATA
From: "Dirigente" <dirigente@scuola.example>
Subject: Urgente

Mi serve un favore...
.
```

- SMTP è nato in una rete di poche università che si fidavano l'una dell'altra
- **MAIL FROM** (la "busta", che diventa Return-Path) e **From:** (quello che vedi) sono due cose diverse
- Nessuno dei due viene verificato dal protocollo base
- Le verifiche sono state aggiunte dopo, nel DNS: SPF, DKIM, DMARC

TRE CONTROLLI NEL DNS

SPF, DKIM, DMARC

SPF

Il dominio pubblica **quali server** possono inviare per lui. Si controlla il dominio della **busta**.

v=spf1 include:_spf.google.com ~all

DKIM

Il server che invia **firma** il messaggio. La chiave pubblica è nel DNS del dominio firmatario.

DKIM-Signature: d=scuola.example; s=sel1; …

DMARC

Il dominio del **From visibile** deve coincidere con quello verificato da SPF o DKIM. E dice che cosa fare se no.

v=DMARC1; p=reject; rua=mailto:…

QUIZ A TRABOCCHETTO

Una mail di phishing ha spf=pass e dkim=pass. Quindi...

QUIZ

A è sicuramente legittima

B è stata inviata dal dominio che vedo nel From

C è stata inviata da un server autorizzato per qualche dominio: bisogna vedere quale

D il filtro antispam non funziona

AL COMPUTER · 15 minuti

Apri il "sorgente" di una mail vera

1. Nella posta scolastica apri una newsletter o una notifica automatica (non una mail personale).
2. In Gmail: menu con i tre puntini, **Mostra originale**.
3. In alto trovi i risultati di **SPF**, **DKIM** e **DMARC**. Annotali in **mail-cognome.md**.
4. Più sotto cerca le righe `Return-Path`, `From` e `DKIM-Signature` (il campo `d=`). I domini coincidono?

Controllo: una newsletter seria mostra **PASS** per tutti e tre. Spesso il Return-Path è di un servizio di invio (per esempio un dominio di mailing), ma DMARC passa grazie alla firma DKIM allineata.

UNA LEZIONE DEL 2002

L'anello che il DNS non protegge

> **Il fattore umano è davvero l'anello più debole della sicurezza.**
>
> **Kevin Mitnick**, ex hacker poi consulente di sicurezza, *L'arte dell'inganno*, 2002

SPF, DKIM e DMARC fermano chi finge di essere il **tuo** dominio. Non fermano chi convince una persona a fidarsi di un dominio **diverso**.

AL COMPUTER · 15 minuti

Leggi le regole di un dominio nel DNS

1. Nel Prompt dei comandi: `nslookup -type=txt google.com` e cerca la riga che inizia con `v=spf1`.
2. Poi: `nslookup -type=txt _dmarc.google.com`
3. Ripeti con il dominio della scuola e con quello di una banca o di un ente pubblico.
4. In **mail-cognome.md** fai una tabella: dominio, SPF con `~all` o `-all`, politica DMARC (`none`, `quarantine`, `reject`).

Controllo: per google.com trovi un record `v=spf1 …` e un record `v=DMARC1; p=…`. Se un dominio non ha il record DMARC, nslookup non trova nulla per `_dmarc`.

PUZZLE

Abbina ogni riga dell'header al suo significato

Received	---	L'indirizzo della busta, a cui tornano gli errori
Return-Path	---	Il mittente che il programma di posta mostra
From	---	I risultati dei controlli scritti dal server che riceve
DKIM-Signature	---	La firma del dominio indicato in d=
Authentication-Results	---	Un passaggio da un server all'altro, il più recente in alto

AL COMPUTER · 20 minuti

Caso: la mail della "banca"

```
Return-Path: <bounce@mailer-promo.example>
Authentication-Results: mx.scuola.example;
  spf=pass smtp.mailfrom=mailer-promo.example;
  dkim=none;
  dmarc=fail header.from=banca-esempio.it
From: "Banca Esempio" <sicurezza@banca-esempio.it>
Reply-To: <verifiche.banca@posta-gratis.example>
Subject: Accesso sospetto: conferma i tuoi dati
```

1. In **mail-cognome.md** scrivi chi ha davvero inviato la mail e da dove si capisce.
2. Perché SPF passa ma DMARC fallisce?
3. A chi arriverebbe la tua risposta?
4. Che cosa succede se banca-esempio.it ha `p=reject`?

Controllo: 4 risposte, tra cui: la mail l'ha spedita **mailer-promo.example**, non la banca; la risposta va a **posta-gratis.example**.

QUANDO DMARC NON BASTA

Domini sosia e account veri

Typosquatting

banca-esempio.co, **banca-esernpio.it** (rn al posto di m): domini dell'attaccante, con SPF e DKIM in regola.

Omografi

Una "a" cirillica identica alla latina. Nel DNS il nome diventa **xn--…** (Punycode).

Account compromesso

La mail parte davvero dalla casella del fornitore, rubata: passa tutto. È la BEC più pericolosa.

> Contro questi casi servono le persone: verifica su un canale diverso per ogni richiesta di soldi o di dati, e procedure che non si saltano "per urgenza".

QUIZ

banca-esempio.it ha DMARC con p=reject. Un attaccante registra banca-esempio-sicura.it e manda mail da lì. DMARC di banca-esempio.it...

QUIZ

A blocca le mail, perché il nome contiene "banca-esempio"

B le manda nello spam

C avvisa la banca vera con un report

D non c'entra: riguarda solo il dominio banca-esempio.it

AL COMPUTER · 25 minuti

Un controllore di allineamento in Java

```
String dominio(String indirizzo) {
  // "Banca" <sicurezza@banca-esempio.it> → banca-esempio.it
  int at = indirizzo.lastIndexOf('@');
  return indirizzo.substring(at + 1)
      .replace(">", "").trim().toLowerCase();
}
```

1. Salva l'header del caso in **caso.txt**. Scrivi **Allineamento.java** che legge le righe `From:`, `Return-Path:` e `Reply-To:`.
2. Stampa i tre domini e un avviso per ogni dominio diverso da quello del From.

Controllo: per il caso della banca stampa due avvisi: Return-Path su **mailer-promo.example** e Reply-To su **posta-gratis.example**.

OGGI

Il phishing senza errori di ortografia





SFIDA A SQUADRE

Apri il lucchetto



- 1ª e 2ª cifra: la porta TCP su cui i server di posta si passano i messaggi
- 3ª e 4ª cifra: quanti controlli nel DNS abbiamo visto oggi (SPF, DKIM, DMARC) moltiplicato per 10, più 2

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Il record che elenca i server autorizzati a inviare per un dominio è _____.

La firma del messaggio con chiave pubblica nel DNS è _____.

DMARC controlla l'_____ con il dominio del From.

La politica DMARC più severa è p=_____.

Le frodi con mail di finti dirigenti o fornitori si chiamano _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- SMTP non verifica il mittente: busta e From sono diversi
- SPF: chi può inviare · DKIM: chi ha firmato
- DMARC: allineamento con il From e politica
- Gli header si leggono, ma solo quelli dei server fidati
- Domini sosia, omografi e account rubati passano i controlli
- Contro la BEC: verifica su un altro canale
- L'AI toglie gli errori, non cambia le difese
- Prossima lezione: Wireshark e l'analisi del traffico

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.